R. AI & Model Governance

Standalone capability brief · Suggested module: **AI Runtime + Model Governance**

Purpose

Offer optional, governed AI capabilities with consistent provider routing, evaluation, cost visibility, privacy controls, safety policies, and operational reliability.

1. Scope and capability areas

Provider and model abstraction

Route requests across approved models and providers while exposing capability differences and avoiding a false lowest-common-denominator API.

Prompt and model versioning

Version prompts, tools, model parameters, retrieval configuration, and deployment settings.

Usage and cost metering

Track tokens or equivalent usage, latency, provider, model version, tenant, and cost attribution.

Evaluation and regression

Maintain evaluation datasets, quality metrics, safety tests, and regression gates for prompt or model changes.

Safety and validation

Apply input/output validation, policy checks, tool permissions, and risk-appropriate human review.

Retrieval permissions

Enforce document access permissions during retrieval and before content is passed to a model.

Reliability and rollout

Handle timeouts, rate limits, fallbacks, staged rollout, and provider-specific degradation.

Privacy and auditability

Redact sensitive data where appropriate and record enough provenance to investigate outputs without retaining unnecessary content.

2. Shared contracts and standards

- AI runtime adoption is optional; non-AI services must not acquire an unnecessary dependency.
- Every AI feature declares data handling, evaluation criteria, permitted tools, fallback behavior, and cost limits.
- Model output is untrusted input and must be validated before it drives actions or is rendered as trusted content.
- Retrieval must preserve source authorization; a model must not become a bypass around document permissions.
- Logging and reproducibility balance investigation needs with data minimization and privacy requirements.

3. Recommended implementation approach

- Create a model gateway with explicit provider capabilities, routing policies, quotas, and timeout budgets.

- Version prompts, evaluation sets, retrieval settings, and model parameters together.
- Use offline evaluations and staged rollout before changing prompts or models in high-impact workflows.
- Track per-tenant cost and latency and set budget limits.
- Apply least privilege to tools and connectors; require confirmation for consequential actions where appropriate.

4. Failure behavior and operational expectations

- Fallbacks must preserve safety and data-handling requirements, not merely switch to any available model.
- If retrieval authorization cannot be verified, do not pass the protected content to the model.
- On timeout or provider failure, return a clear degraded response or safe alternative instead of fabricating success.
- Escalate uncertain or high-impact decisions to deterministic rules or human review where needed.

5. Suggested operational metrics

- Quality and safety evaluation scores
- Cost and latency by model and tenant
- Fallback and timeout rates
- Unauthorized retrieval test failures
- Prompt/model regression incidents
- Sensitive-data leakage findings

6. Readiness and acceptance checklist

- ■ AI features have versioned prompts, models, and evaluations.
- ■ Costs and latency are attributable to tenants and features.
- ■ Retrieval respects source permissions end to end.
- ■ Fallbacks preserve policy and privacy constraints.
- ■ Model changes have measurable release gates and rollback paths.

Ownership note: assign a named team, service owner, support route, versioning policy, and deprecation process before treating this capability as a platform contract.